Chapitre 6

La gestion des clés de chiffrement

Dr.Wafa Berrayana | AU: 2025-2026

Cycle de vie d'une clé de chiffrement

- Les principales étapes du **cycle de vie d'une clé de chiffrement**:
  - **Génération :** Création de la clé de manière sécurisée, souvent à l'aide d'un générateur de nombres aléatoires cryptographiquement sûr comme HSM, KMS
  - **Stockage sécurisé :** conserver la clé dans un HSM ou un service KMS (Key Management Service) ; jamais en clair dans le code ou sur un dépôt.
  - **Distribution :** Transmission de la clé vers les utilisateurs ou dispositifs autorisés, de manière confidentielle.
  - **Utilisation :** Emploi de la clé pour chiffrer, déchiffrer ou signer des données au sein des processus cryptographiques
  - **Rotation/Renouvellement :** Remplacement périodique de la clé pour réduire les risques liés à sa compromission et renforcer la sécurité
  - **Révocation/destruction:** Suppression définitive ou invalidation de la clé devenue inutile, compromise ou expirée

- HSM (Hardware Security Module) — stockage matériel sécurisé des clés, opérations cryptographiques sans exposer la clé en clair
- KMS (Key Management Service) — service managé (AWS KMS, Azure Key Vault, Google KMS) : gestion, rotation, permissions, audit.
- Envelope encryption — chiffrer les données avec une clé de données (DEK) et chiffrer la DEK avec une clé maîtresse (KEK); minimise exposition des KEK
- BYOK / HYOK — Bring Your Own Key / Hold Your Own Key : entreprises gèrent leur propre clé dans le cloud.

Techniques de distribution des clés publiques

2025

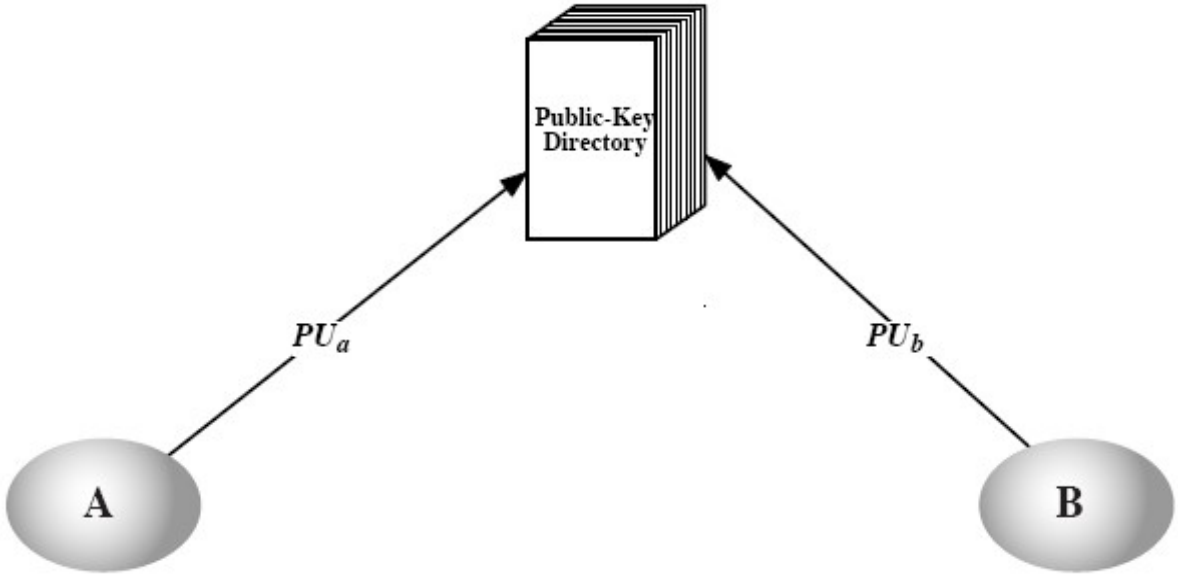
Annonce publique (Public announcement)

- C'est la méthode la plus simple. La publication de la clé publique se fait de manière ouverte (par exemple sur un site web, un forum, un e-mail, etc.).
  - **Avantage :** facile à mettre en place.
  - **Inconvénient :** pas de garantie d'authenticité — un attaquant peut publier une fausse clé en se faisant passer pour quelqu'un d'autre (attaque de l'homme du milieu).



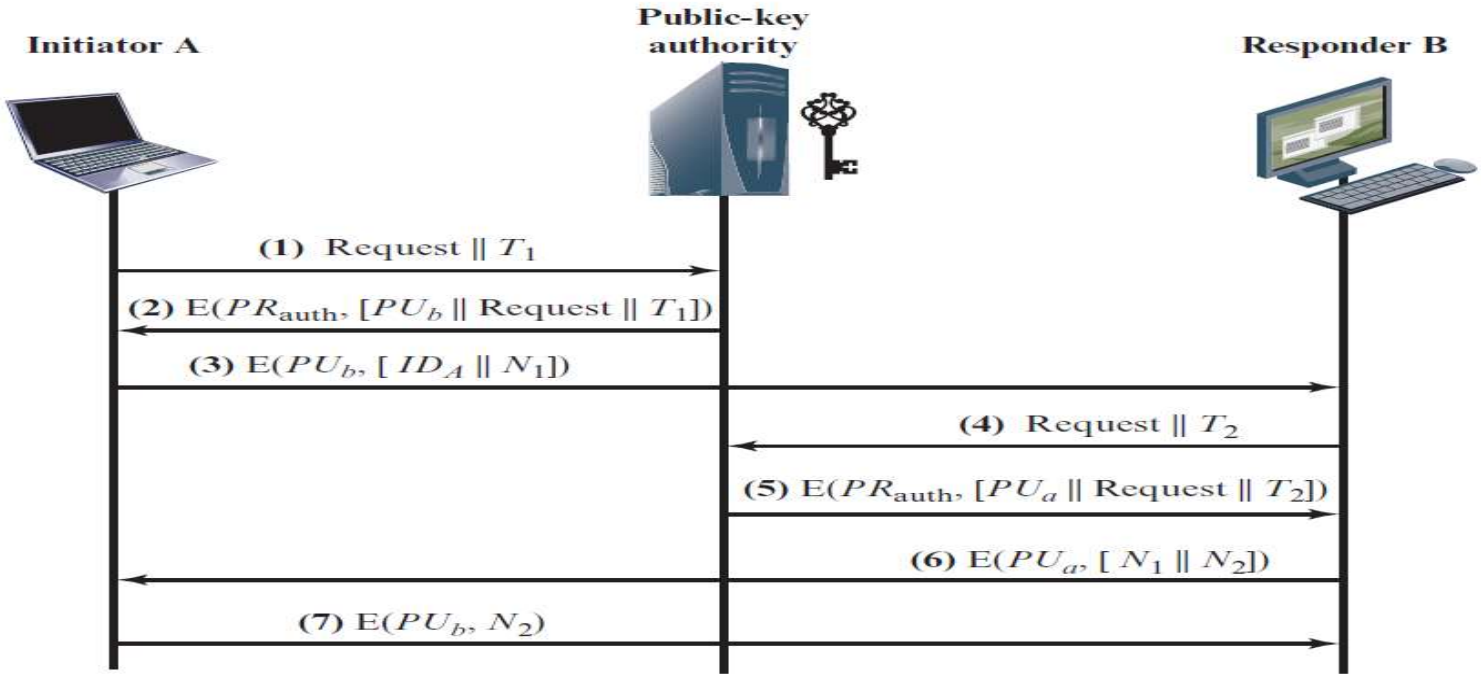
Annuaire public (Publicly available directory)

- une organisation gère un annuaire où les utilisateurs peuvent consulter les clés publiques associées à chaque identité
  - **Avantage :** plus fiable qu'une annonce libre, car l'annuaire est centralisé.
  - **Inconvénient :** il faut faire confiance à la sécurité et à l'intégrité de l'annuaire. Si celui-ci est compromis, les clés peuvent être remplacées.



Autorité de clé publique (Public-key authority)

- Une **autorité de clé publique** (PKA) agit comme un tiers de confiance. Lorsqu'un utilisateur veut obtenir la clé publique d'un autre, il en fait la demande à l'autorité, qui répond avec la clé signée et vérifiée
  - **Avantage :** l'authenticité est assurée par une autorité fiable.
  - **Inconvénient :** dépendance à un tiers (si l'autorité est indisponible ou compromise, le système est affecté).

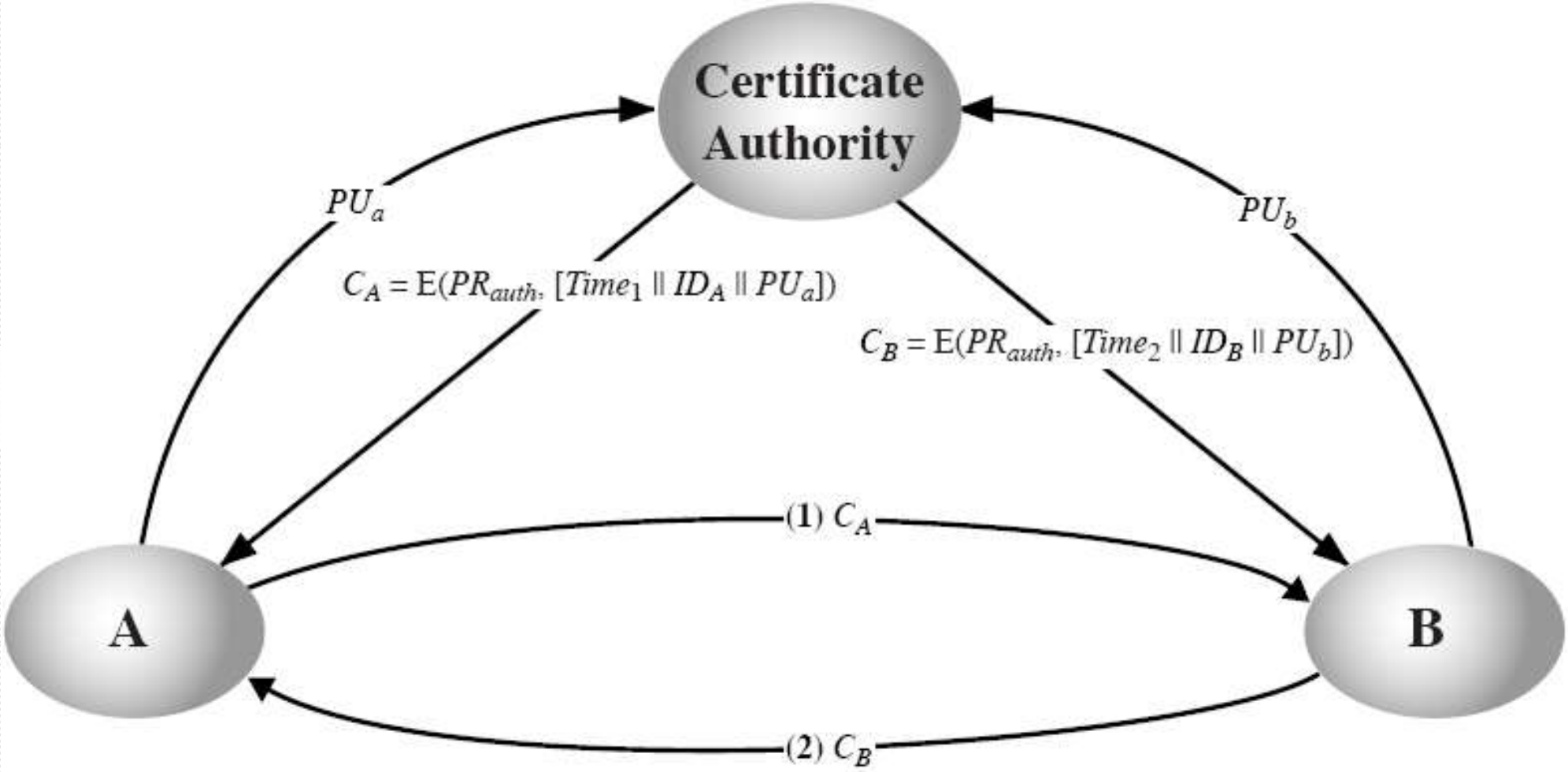


Public-Key Distribution Scenario

Certificats de clé publique (Public-key certificates (1)

- Les **certificats** (comme les certificats SSL/TLS sur Internet) sont délivrés par une **autorité de certification (CA)**
- Un certificat relie une clé publique à l'identité de son propriétaire, et cette liaison est **signée numériquement** par la CA
  - **Avantage :** le certificat peut être vérifié sans contacter directement la CA à chaque fois (la signature suffit).
  - **Inconvénient :** nécessite une infrastructure à clé publique (PKI) et la gestion des certificats (émission, révocation, renouvellement).

Certificats de clé publique (Public-key certificates (2)



Techniques de distribution des clés privées

2025

- **Dans la cryptographie symétrique**, la **distribution de la clé secrète/privée/symétrique** est **le point le plus critique**
- Contrairement à la cryptographie asymétrique (où seule la clé publique est partagée), ici **les deux parties doivent posséder la même clé secrète**, sans qu'un tier ne puisse l'intercepter



Le problème fondamental: Comment échanger cette clé sans qu'un attaquant ne puisse la lire ou la modifier ?

Distribution physique sécurisée

- C’est la méthode la plus simple mais la **moins pratique**
- La clé est transmise **par un canal physique sûr** : clé USB chiffrée, courrier sécurisé, remise en main propre, etc.
- **Exemple :** militaires, diplomatie, ou certaines entreprises critiques utilisent encore ce mode
  - **Avantage :** très sûr si le canal est contrôlé.
  - **Inconvénient :** peu scalable (impossible de gérer des milliers d’échanges).

Utilisation d'un canal de communication sécurisé préexistant

- Si un **canal sécurisé** existe déjà (VPN, TLS, SSH, etc.), on peut **échanger la clé symétrique à travers ce canal**.
- Exemple : un serveur génère une clé AES et l'envoie au client via une **connexion TLS**
  - **Avantage :** simple, automatisable.
  - **Inconvénient :** dépend d'un canal déjà sécurisé — donc pas utile au tout premier échange.

Utilisation d'un algorithme d'échange de clé (comme Diffie-Hellman) (1)

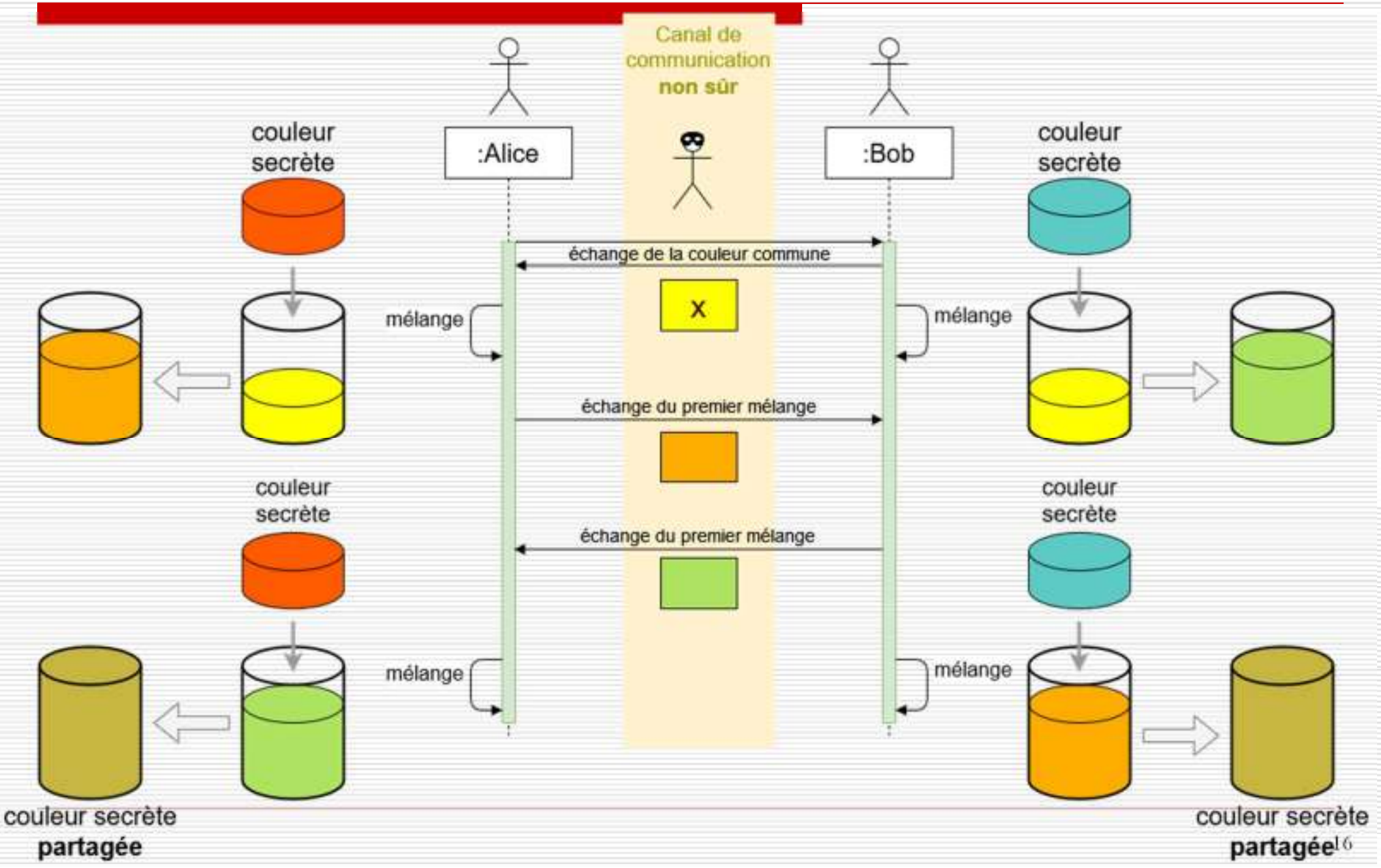
- **Contrairement** à ce que l'on pourrait penser, dans la méthode d'échange de clés Diffie-Hellman (DH), il n'y a pas à proprement parlé de communication directe de clés
- Voir cet algorithme avec le concept des **"Puzzles de Merkel"**
  ➔ On échange seulement des **paramètres publics** qui seront utilisés pour **créer simultanément chez les deux interlocuteurs une même clé secrète**

- **Avantage :** aucune clé secrète n'est transmise sur le réseau
- **Inconvénient :** vulnérable aux attaques "man-in-the-middle" si les clés publiques ne sont pas authentifiées (d'où l'usage de certificats en pratique).

Utilisation d'un algorithme d'échange de clé (comme Diffie-Hellman) (2)

- **Exemple concret :**
  - Alice et Bob choisissent un grand nombre premier et une base publique
  - Chacun choisit un secret privé et calcule une valeur publique.
  - Ils échangent les valeurs publiques.
  - En combinant sa clé privée et la clé publique reçue, chacun retrouve la même clé secrète → Cette clé devient leur clé symétrique pour le chiffrement AES, par exemple.

Utilisation d'un algorithme d'échange de clé (comme Diffie-Hellman) (3)



Utilisation d'une infrastructure de gestion de clés (KMS ou HSM)

- Dans les systèmes modernes (cloud, entreprises), la distribution se fait **automatiquement** via un **service de gestion de clés** :
  - **KMS** (Key Management Service, ex : AWS KMS, Azure Key Vault, Google KMS)
  - **HSM** (Hardware Security Module)
- Le KMS ou HSM :
  - Génère la clé.
  - La stocke de manière sécurisée.
  - La transmet chiffrée ou via des API sécurisées aux entités autorisées.
- **Avantage :** sécurité élevée, audit, rotation automatique.
- **Inconvénient :** dépend d'une infrastructure tierce.

Chiffrement d'enveloppe (Envelope Encryption)

- Une autre approche hybride :
  1) On génère une clé de données symétrique (DEK) pour chiffrer un fichier ou message.
  2) Cette DEK est ensuite **chiffrée avec une clé maîtresse (KEK)** stockée dans un KMS.
  3) La DEK chiffrée est envoyée avec les données

- Ainsi, la **vraie clé symétrique** n'est jamais exposée en clair.

En résumé

Méthode	Principe	Avantage	Inconvénient
Physique	Remise manuelle (clé USB, papier)	Très sûr	Non scalable
Canal sécurisé	Utiliser TLS/VPN/SSH	Simple	Nécessite canal déjà sûr
Diffie–Hellman	Échange mathématique sécurisé	Pas de clé transmise	Besoin d'authentification
KMS / HSM	Distribution centralisée	Haute sécurité	Coût / dépendance infra
Envelope Encryption	Clé symétrique chiffrée par clé maîtresse	Très sûr, flexible	Complexité de gestion

La cryptographie et la technologie quantique

La **technologie quantique** repose sur les principes de la **mécanique quantique**, une branche de la physique qui décrit le comportement des particules à très petite échelle

Menace sur la cryptographie classique

- Les ordinateurs quantiques peuvent **briser certains algorithmes cryptographiques actuels**
- **Algorithmes vulnérables :**
  - **RSA**, **DSA**, **Diffie-Hellman**, **ECC** (courbes elliptiques)
    - tous basés sur des problèmes mathématiques “difficiles” (factorisation, logarithme discret)
    - L’**algorithme de Shor** (1994) peut les résoudre en un temps polynomial sur un ordinateur quantique
  - **AES** et autres algorithmes symétriques
    - l’**algorithme de Grover** divise par deux la sécurité effective (ex AES-256 devient équivalent à AES-128)
    - donc encore sûr, mais il faut **doubler la taille des clés**.
- **En clair :**



Un ordinateur quantique suffisamment puissant pourrait **casser la plupart des protocoles de sécurité Internet actuels** (HTTPS, VPN, signatures numériques…).

La cryptographie post-quantique

- C’est la réponse de la communauté scientifique

  - Concevoir des algorithmes **résistants aux attaques quantiques**, mais qui tournent sur **des ordinateurs classiques**.

Aspect	Cryptographie classique	Cryptographie post-quantique	Cryptographie quantique
Basée sur	Mathématiques (factorisation, logarithme discret, etc.)	Mathématiques résistantes aux attaques quantiques	Lois de la physique quantique
Vulnérable aux ordis quantiques ?	Oui	Non	Non
Matériel requis	Classique	Classique	Matériel quantique

La cryptographie post-quantique

- **Principales familles d'algorithmes post-quantiques :**

Famille	Principe	Exemple
Basée sur les réseaux (lattices)	Difficulté de trouver un vecteur court dans un réseau	Kyber, Dilithium (normalisés par NIST)
Basée sur les codes correcteurs d'erreurs	Décodage de code linéaire difficile	Classic McEliece
Basée sur les multivariées	Résolution d'équations polynomiales multivariées	Rainbow
Basée sur les isogénies de courbes elliptiques	Transformations complexes entre courbes	SIKE (abandonné après attaque)
Basée sur les hachages	Sécurité fondée sur les fonctions de hachage	SPHINCS+